

Bug Report — Authentication Feature

Performed by: Lê Kim Hằng **Reviewed by:** Lê Kim Hằng **Edited by:** Lê Kim Hằng

BUG-001

Related Test Case: TC-REG-004

Title: Weak/too-short password is accepted during registration

Description: When registering a new account with a password that does not meet the minimum length/complexity requirement, the system creates the account successfully instead of rejecting the request. Password-policy validation appears to be missing or not enforced on the registration flow.

Steps to Reproduce:

1. Go to `/register`.
2. Enter a valid, unique email and a valid name.
3. Enter a weak/too-short password.
4. Click "Register".

Expected Result: Registration is rejected with a validation error explaining the password requirement.

Actual Result: The account is created successfully with the weak password; no validation error is shown.

Severity: Medium

Status: Open

Fix Description: [To be filled in once the backend/frontend password-policy validation is implemented and re-tested.]

BUG-002

Related Test Case: TC-LOGIN-006

Title: No account lockout after repeated failed login attempts

Description: The system does not implement any rate-limiting or account-lockout mechanism for consecutive failed login attempts. This leaves the login endpoint vulnerable to brute-force password guessing.

Steps to Reproduce:

1. Attempt to log in with a valid, registered email and an incorrect password 5 times in a row.
2. Attempt a 6th login (with either correct or incorrect password).

Expected Result: On the 6th attempt, the system blocks the login attempt, even if the credentials are correct.

Actual Result: The 6th (and any subsequent) login attempt is processed exactly like the first, no logout, throttling, or warning message is triggered. A correct password on the 6th attempt still logs the user in normally.

Severity: High

Status: Open

Fix Description: [To be filled in once a logout/rate-limiting mechanism is implemented and re-tested. TC-LOGIN-007 (logout expiry) also depends on this fix and cannot be verified until it is resolved.]

BUG-003

Related Test Case: TC-LOGIN-009

Title: Access token expiry does not match documented 15-minute policy

Description: The Non-Functional/Security Requirements (PA2 Vision Document) and the test case specification state that the `accessToken` should expire after 15 minutes. In the actual implementation, the web app's `accessToken` remains valid for approximately 1 day. This is either a spec-compliance defect in the backend token configuration, or the security documentation is outdated and needs to be corrected to match the intended design.

Steps to Reproduce:

1. Log in and obtain a valid `accessToken`.
2. Wait 15+ minutes without renewing the token.
3. Call a protected API (e.g. `GET /user/profile`) using that token.

Expected Result: Request is rejected with HTTP 401 (token expired), per the documented 15-minute access token policy.

Actual Result: Request still succeeds after 15 minutes; the token is only rejected after approximately 1 day, indicating the actual configured expiry is 1 day rather than 15 minutes.

Severity: Medium

Status: Open

Fix Description: [To be filled in — team needs to decide whether to (a) update the backend JWT expiry config to match the documented 15-minute policy, or (b) formally update the NFR/security documentation to reflect the intended 1-day expiry, then re-test.]
